Security & Privacy Disclosure, Final Report

immowelt Android (de.immowelt.android.immobiliensuche)

Credentials for the Auth0 tenant and the Airship push platform ship in cleartext in every copy of Germany’s second-largest property portal app, alongside a Firebase key and two advertising SDKs that start before the consent dialog, and across ten messages and 109 days the company sent no reply of any kind, not even an automated acknowledgement

PUBLIC DISCLOSURE, 17 OCTOBER 2026 - EMBARGO REACHED 28 SEPTEMBER 2026, TEN MESSAGES SENT, NO REPLY OF ANY KIND RECEIVED

Target	AVIV Germany GmbH (immowelt), Nuernberg
Package	de.immowelt.android.immobiliensuche, v11.45.0 (versionCode 1454)
Platform Audited	Android, static analysis of the production APK
Initial Disclosure (R1)	2026-06-30, to datenschutz@immowelt.de and security@immowelt.de (first letter) and to datenschutz@immowelt.de and presse@immowelt-group.de (second letter, REF IW-2026-R1-001)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	7 (4 Critical, 3 High)
Correspondence	10 messages sent by RFI-IRFOS over 62 days of active follow-up (2026-06-30 to 2026-08-31), no reply, no automated acknowledgement received
Authorities Notified	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) and European Data Protection Supervisor (edps@edps.europa.eu) in CC from the follow-ups of 2026-07-23 and 2026-08-09; the addresses used for the Austrian authority and for the Bavarian authority (BayLDA) in the second R1 bounced on 2026-06-30

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 5

4.1 C1: Auth0 client secret and three client IDs hardcoded in the production binary 5

4.2 C2: Airship app key and app secret hardcoded in the production binary 6

4.3 C3: Firebase API key and Google Maps key are the same credential, hardcoded with the Firebase database URL 6

4.4 C4: Firebase and AdMob initialize as ContentProviders before any consent dialog, Firebase even before device unlock 7

4.5 H1: Adjust attribution token hardcoded, feeding a five-platform advertising stack including TikTok/ByteDance 7

4.6 H2: Household income, housing-benefit status and employment status are shared with unnamed "external service providers" 8

4.7 H3: RECORD_AUDIO permission and call-tracking data sent to "AVIV Group entities and our external service providers" 8

5 Impact Analysis 9

6 The Complete Chain: Ten Messages, Zero Replies 9

7 Data Protection – Article by Article 9

8 Regulatory & Legal Landscape 10

9 Indicators of Compromise 10

10 Disclosure Timeline & Outcome 10

11 Residual Risk & Recommendations 11

Executive Summary

immowelt is the Android property-search app of AVIV Germany GmbH, a subsidiary of the AVIV Group, and one of the two largest property portals in Germany. Users of the app submit household monthly net income, housing-benefit status and employment status to landlords through contact forms. A static analysis of the production APK (v11.45.0) found seven findings, four CRITICAL and three HIGH.

The binary contains an Auth0 client secret with all three client IDs (C1), the Airship push-platform app key and app secret (C2), and a Google API key that doubles as Firebase and Maps credential (C3), all in cleartext. Two ContentProviders, Firebase and AdMob, initialize before the consent dialog can render (C4). A hardcoded Adjust token feeds five advertising platforms including TikTok/ByteDance (H1). Income and call-tracking data go to recipients that the app describes only as "external service providers" (H2, H3). All secret values are withheld from this public report; they were disclosed privately to immowelt in the original R1 letters.

RFI-IRFOS disclosed the findings on 30 June 2026 in two letters on the same day, stating an embargo of 28 September 2026. Eight follow-ups on 6, 17, 23 and 31 July and on 9, 15, 24 and 31 August 2026 repeated the findings and three questions, among them whether the Auth0 and Airship secrets had been rotated. immowelt never replied and never sent an automated acknowledgement. The embargo of 28 September 2026 passed 19 days before this report, with every question unanswered.

ID	Severity	Title
C1	CRITICAL	Auth0 client secret and three client IDs hardcoded in the production binary
C2	CRITICAL	Airship app key and app secret hardcoded in the production binary
C3	CRITICAL	Firebase API key and Google Maps key are the same credential, hardcoded with the Firebase database URL
C4	CRITICAL	Firebase and AdMob initialize as ContentProviders before any consent dialog, Firebase even before device unlock
H1	HIGH	Adjust attribution token hardcoded, feeding a five-platform advertising stack including TikTok/ByteDance
H2	HIGH	Household income, housing-benefit status and employment status are shared with unnamed "external service providers"
H3	HIGH	RECORD_AUDIO permission and call-tracking data sent to "AVIV Group entities and our external service providers"

Subject & Operator Context

immowelt is operated by AVIV Germany GmbH, Nuernberg, part of the AVIV Group. The data protection officer named in public sources is an external provider in Hamburg. RFI-IRFOS wrote to datenschutz@immowelt.de, security@immowelt.de and presse@immowelt-group.de. No delivery failure was recorded for any of these three addresses.

Engagement Summary

On 30 June 2026 RFI-IRFOS sent two disclosure letters: one to datenschutz@immowelt.de and security@immowelt.de covering the Auth0, Airship and Firebase credentials and the pre-consent Adjust initialization, and one to datenschutz@immowelt.de and presse@immowelt-group.de (REF IW-2026-R1-001) covering the Firebase key, the pre-consent Firebase and AdMob initialization, the Adjust token, the income data flow and the call tracking. Both stated the embargo of 28 September 2026. The addresses for the Austrian and the Bavarian supervisory authority used in the second letter returned delivery failures the same day; from 23 July 2026 the Austrian authority and from 9 August 2026 the EDPS were in CC at working addresses.

Follow-ups of 6 July, 17 July, 23 July, 31 July, 9 August, 15 August, 24 August and 31 August 2026 repeated the findings and the questions on record, including the 17 July message that named the Auth0 client secret and the Airship app secret and asked whether they had been rotated. No reply of any kind arrived, and the embargo passed on 28 September 2026.

Findings

C1: Auth0 client secret and three client IDs hardcoded in the production binary

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N, 9.3 - credentials reachable by anyone who holds the app

```
res/values/strings.xml
client_secret: [REDACTED IN PUBLIC REPORT -- disclosed privately in R1]
auth0_client_id_development / _preview / _production: [REDACTED IN PUBLIC REPORT]
Reachable by: any party decompiling the published APK
```

Impact: An Auth0 client secret and the development, preview and production client IDs are stored in cleartext in the app's string resources, present in every installed copy of v11.45.0 and extractable by anyone who decompiles the APK (all values withheld from this public report; full values were disclosed privately to immowelt in the original R1 letter). A client secret belongs on a server. Held by the public, it allows any party to present itself to the Auth0 tenant as the legitimate app client. For a portal where users submit household income and employment status to landlords, this is a direct failure of the technical-measures requirement of Art. 32 and the data-protection-by-design principle of Art. 25.

C2: Airship app key and app secret hardcoded in the production binary

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:N/SC:N/SI:N/SA:N, 9.3 - push access to every registered user

```
res/values/strings.xml
airship_app_key: [REDACTED IN PUBLIC REPORT -- disclosed privately in R1]
airship_app_secret: [REDACTED IN PUBLIC REPORT -- disclosed privately in R1]
```

Impact: The Airship push-messaging app key and the app secret are stored in cleartext in the app's string resources (both withheld from this public report; full values were disclosed privately in the original R1 letter). Airship's own documentation classifies the app secret as confidential and not for embedding in client code. In the hands of any party that holds the APK, the secret grants server-side push-platform access, which includes sending push notifications to registered users without involving immowelt's own backend. Push to every installed device is a phishing channel with the credibility of the real app.

C3: Firebase API key and Google Maps key are the same credential, hardcoded with the Firebase database URL

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 9.1 - one key, two services, reachable by anyone who decompiles the app

```
res/values/strings.xml
google_api_key: AIzaSyCHXG... [remainder withheld]
google_maps_api_key: AIzaSyCHXG... [identical value, remainder withheld]
firebase_database_url / project_id: [REDACTED IN PUBLIC REPORT]
```

Impact: A single Google API key (AIzaSyCHXG..., remainder withheld) serves both Firebase and Google Maps, so the exposure of one surface is the exposure of both. The Firebase project identifier and Realtime Database URL ship in the same file. This creates a quota and billing exhaustion surface against the underlying Google Cloud project and, if the database rules are not deny-by-default, an unauthenticated read surface. Under Art. 5(2) the burden of showing that no such exposure exists rests with the controller. The app's users disclose household income and employment status in contact forms, which raises the cost of any exposure.

C4: Firebase and AdMob initialize as ContentProviders before any consent dialog, Firebase even before device unlock

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.2 - Firebase and AdMob run before consent on a financial-profile audience

```
com.google.firebase.provider.FirebaseInitProvider -- directBootAware=true, initOrder
    =100
com.google.android.gms.ads.MobileAdsInitProvider -- initOrder=100
Usercentrics CMP present in the same APK, starts after the Activity lifecycle
```

Impact: FirebaseInitProvider (directBootAware=true, initOrder=100) and MobileAdsInitProvider (AdMob, initOrder=100) are declared as ContentProviders in the manifest, so Android starts them before any Activity exists and therefore before the Usercentrics consent dialog can render. The consent platform is present in the app, but it cannot gate what the operating system starts at process creation. RFI-IRFOS blast-radius escalation: raised from HIGH/7.2 to CRITICAL because the app is Germany's second-largest property portal, its users submit household income and employment status to landlords, and an advertising platform initializing before consent on that audience builds a targeting signal on financial circumstances (housing intent plus income bracket) without an Art. 6(1)(a) basis.

H1: Adjust attribution token hardcoded, feeding a five-platform advertising stack including TikTok/ByteDance

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.2 - five advertising platforms fed from housing-search events

```
res/values/strings.xml
adjust_app_token: [value withheld in this public report]
user_centrics_template_id_adjust_{criteo,tiktok,meta,googleAds}: present
adjust_deeplink_host: immowelt.go.link
```

Impact: The Adjust app token is stored in cleartext and the Adjust SDK is wired to Criteo, TikTok/ByteDance, Meta, Google Ads and Google Ad Manager through per-platform Usercentrics templates. Each property view, contact submission and calculator use is an attributable event. The privacy information available in the app names no Art. 44-49 transfer mechanism for the flow to a platform controlled by ByteDance. Because the token is public, any party can also inject fabricated conversion events into the attribution data.

H2: Household income, housing-benefit status and employment status are shared with unnamed "external service providers"

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.0 - financial profile data with an unnamed recipient class

```
cdpSeeker_contactForm_monthly_income: Household monthly net income
cdpSeeker_contactForm_monthly_income_housing_benefit: I receive housing benefit
ef_resultsStepContactFormLegalDE_text: "...AVIV Group entities and external service
    providers"
```

Impact: The contact form collects household monthly net income in eight brackets, whether the user receives housing benefit, and work status. The legal text shown at submission says the data is shared with "AVIV Group entities and external service providers" without naming a single recipient. Art. 13(1)(e) requires the recipients or categories of recipients to be identified, and the collection of an income bracket and benefit status at first contact is open to challenge under data minimisation (Art. 5(1)(c)).

H3: RECORD_AUDIO permission and call-tracking data sent to "AVIV Group entities and our external service providers"

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.0 - audio permission plus call tracking to unnamed recipients

```
AndroidManifest.xml: android.permission.RECORD_AUDIO
cdpSeeker_call_callTracking_data_legalText_android: "...transmit this data to our AVIV
     Group entities and our external service providers."
```

Impact: The app declares RECORD_AUDIO and implements call tracking whose legal text states that call data is transmitted to AVIV Group entities and external service providers, again without naming them. A phone call to a landlord is the highest-intent event in a housing search. Call timing and outcome, combined with the income and employment profile from H2, form a granular behavioural profile, and no purpose limitation or recipient list is given.

Impact Analysis

The three credential findings (C1, C2, C3) are engineering failures with a direct fix: rotate, remove from the client, and move the operations that need them to a server. The pre-consent and recipient findings (C4, H1 to H3) are consent-architecture and transparency gaps. None of this indicates bad faith. What distinguishes this case is the correspondence: ten messages over 62 days to the privacy, security and press mailboxes, including direct questions on rotation of two secrets that cannot be safe while they remain in a published binary, and no response of any kind.

The Complete Chain: Ten Messages, Zero Replies

Step 1 - Disclosure: two R1 letters on 30 June 2026, embargo 28 September 2026 stated in both.

Step 2 - Follow-ups: 6 July, 17 July (Auth0 and Airship named, rotation asked), 23 July, 31 July (Art. 33(4) GDPR notice added), 9 August, 15 August, 24 August and 31 August 2026.

Step 3 - Silence: no reply and no automated acknowledgement to any of the ten messages, across 62 days of follow-up.

Step 4 - Embargo passes: 28 September 2026, with no contact from immowelt.

Step 5 - Publication: this report publishes 19 days after the embargo with the record intact.

Data Protection – Article by Article

Art. 32(1)(b),(d) and Art. 25 GDPR: C1, C2 and C3 fall short of the technical measures and d ata-protection-by-design requirements.

Art. 7 and Art. 6(1) GDPR: C4 starts Firebase and AdMob before any consent interaction.

Art. 13(1)(e) and Art. 5(1)(c) GDPR: H2 and H3 name no recipients for income and call-tracking data and collect more than first contact requires.

Art. 44-49 GDPR: H1 sends housing-search events to a platform controlled by ByteDance with no transfer mechanism identified in the app’s privacy information.

Regulatory & Legal Landscape

The lead supervisory authority for AVIV Germany GmbH, Nuernberg, is the Bavarian state authority for data protection supervision (BayLDA). RFI-IRFOS did not reach it by e-mail: the address used in the second R1 returned a delivery failure and no working address was established afterwards. The Austrian authority and the EDPS were in CC at working addresses from the follow-ups of 23 July and 9 August 2026.

Fine exposure under GDPR: Art. 83(4) applies to the Art. 32 and Art. 25 issues in C1 to C3, up to EUR 10,000,000 or 2% of total worldwide annual turnover. Art. 83(5) applies to the Art. 6, 7, 13 and 44-49 issues in C4 and H1 to H3, up to EUR 20,000,000 or 4% of total worldwide annual turnover.

Indicators of Compromise

All findings were extracted from the production APK by static analysis only. No immowelt or AVIV servers, accounts or infrastructure were probed, and no credential was used. Secret values for C1 and C2, the database URL and project identifier for C3 and the Adjust token for H1 are withheld from this public report.

```
C1 -- Auth0 client secret + 3 client IDs, redacted
C2 -- Airship app key + app secret, redacted
C3 -- Google API key (Firebase + Maps), truncated AIzaSyCHXG...
C4 -- FirebaseInitProvider + MobileAdsInitProvider before consent
H1 -- Adjust token, five advertising platforms
H2 -- income / benefit / work status to unnamed recipients
H3 -- RECORD_AUDIO + call tracking to unnamed recipients
```

Disclosure Timeline & Outcome

2026-06-30 Two R1 letters sent (first letter 05:25 UTC to datenschutz@ and security@, second letter 13:19 UTC to datenschutz@ and presse@immowelt-group.de, REF IW-2026-R1-001). Embargo stated as 2026-09-28. Delivery failures for the authority addresses in the second letter.

2026-07-06 Follow-up. No reply.

2026-07-17 Follow-up naming the Auth0 and Airship secrets, asking whether they were rotated. No reply.

2026-07-23 Follow-up, Austrian authority in CC. No reply.

2026-07-31 Follow-up, three questions repeated, Art. 33(4) GDPR notice added. No reply.

2026-08-09 Follow-up, EDPS in CC. No reply.

2026-08-15 Follow-up. No reply.

2026-08-24 Follow-up. No reply.

2026-08-31 Follow-up, the ninth message on the second thread. No reply.

2026-09-28 Embargo date reached and passed, no contact from immowelt.

2026-10-17 This report published, 19 days after the embargo. Correspondence record: ten messages sent, zero replies, zero automated acknowledgements.

Residual Risk & Recommendations

C1 – Immediate: rotate the Auth0 client secret, remove it from the client, and review the tenant's logs and grants for use of the exposed credential.

C2 – Immediate: rotate the Airship app secret and key, move any operation that needs the secret to a server, and review sent push campaigns.

C3 – Immediate: rotate the Google API key, restrict it by application and API, and verify that the Realtime Database rules deny by default.

C4 – Defer Firebase and AdMob initialization until the consent decision, by disabling the auto-init providers in the manifest.

H1 – Document an Art. 44-49 safeguard for the transfer to TikTok/ByteDance or remove the integration, and rotate the Adjust token.

H2 and H3 – Name the recipients in the privacy information, and collect income, benefit and call data only where first contact requires it.

Procedural: RFI-IRFOS remains open to a substantive answer to the questions on record at any time; this report will be updated to reflect one if it arrives.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No immowelt or AVIV infrastructure was probed and no credential was used. Secret values referenced in findings C1 to C3 and H1 are withheld from this public report; full values were disclosed privately to immowelt in the original R1 letters and remain available to immowelt or to a supervisory authority on request. Technical evidence is archived under chain of custody. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF IMMOWELT-2026-R1-001.